

تقرير التحليل الفني الشامل لمنظومة ال Backend

الحالة الإجمالية: 8 ميزات تم
التحقق منها

التاريخ: 25
سبتمبر 2026

النوع: فحص شامل وتفصيلي للميزات
(Feature-by-Feature)

المشروع: Church History
API / اعداد خدام

1. البنية التقنية العامة (Architecture & Overview)

قاعدة البيانات: PostgreSQL مستضافة على Supabase عبر مكتبة
supabase/supabase-js مع حماية Row Level Security (RLS)
وحصر الوصول بمفتاح الخدمة Service Role.

البيئة وإطار العمل: Node.js (ES Modules - Version 20+/24)
بدون أي إطار عمل خارجي مثل Express/NestJS؛ يعتمد على Node
Native HTTP لل خادم المحلي و Vercel Serverless Functions
للاستضافة.

الخدمات الخارجية: سيرفر SMTP لإرسال رسائل التنبيه وإعادة
تعيين كلمة المرور عبر nodemailer. لا توجد أي مهام خلفية
مجدولة (Background Jobs).

نظام التوثيق: رموز JWT صادرة عن السيرفر بخوارزمية HS256
وصلاحية 7 أيام، وتشفير كلمات المرور بـ bcryptjs (12 Salt
Rounds).

2. مصفوفة الميزات والـ APIs (Summary Matrix)

الميزة	Endpoint الـ	الطريقة	التوثيق (Auth)	العملية في DB	الحالة
User .1 Registration	api/register/	POST	عام (Public)	SELECT, INSERT, DELETE (Rollback)	جزئي ⚠️ (CORS)
User Login & .2 Session	api/login/	POST	عام (يصدر JWT)	SELECT	جزئي ⚠️ (CORS)
Current User .3 Profile	api/me/	GET	Bearer JWT	SELECT	جزئي ⚠️ (CORS)
Email .4 Verification	api/verify-email/	GET	Token Param	SELECT, UPDATE	يعمل ✅ بالكامل
Resend .5 Verification	api/resend-/ verification	POST	عام (Public)	SELECT, UPDATE	جزئي ⚠️ (SMTP)
Forgot Password .6	api/forgot-password/	POST	عام (Public)	SELECT, UPDATE	جزئي ⚠️ (SMTP)
Reset Password .7	api/reset-password/	POST	Token Body	SELECT, UPDATE	يعمل ✅ بالكامل
Health .8 Diagnostics	api/health/	GET	عام (Public)	SELECT (Limit 1)	يعمل ✅ بالكامل

3. الفحص التفصيلي لكل ميزة (Feature-by-Feature Deep Dive)

PARTIALLY WORKING ⚠️

Feature 1: User Registration (تسجيل حساب جديد)

- الغرض (Purpose):** تسجيل حساب مستخدم جديد، تشفير كلمة المرور بـ Bcrypt، وحفظ بيانات المستخدم في جدول `public.users` في Supabase، مع توليد رمز تفعيل عشوائي وإرساله عبر البريد الإلكتروني.
- مسار المعالجة (Flow):** `Frontend (POST /api/register) → backend/api/register.js` → Supabase لمنع تكرار البريد → تجزئة كلمة المرور → إدراج السجل → إرسال بريد التفعيل عبر Nodemailer.
- تفاصيل الـ API:** `POST /api/register` | الحقول المطلوبة: `{ name, email, password }` | الاستجابة: `201 Created` مع رسالة توجيهية.
- القواعد البرمجية (Business Rules):** - كلمة المرور 8 محارف على الأقل.
- إذا كان `SMTP_PASS` غير معرف بالسيرفر، يتم تفعيل الحساب تلقائياً لتسهيل التطوير.
- في حال فشل إرسال البريد يتم التراجع وحذف السجل المضاف فوراً (Rollback).

المشكلة المرصودة: على خوادم Vercel Serverless يرفض المسار طلبات المتصفح التمهيدية `OPTIONS` بكود `405 Method Not Allowed`، مما يسبب فشل الـ `CORS` من المتصفح في الإنتاج.

PARTIALLY WORKING ⚠️

Feature 2: User Login & Session (تسجيل الدخول وإصدار الجلسة)

- الغرض:** التحقق من صحة بيانات الدخول والتأكد من تفعيل البريد الإلكتروني، ثم إصدار رمز `JWT` مشفر يمثل جلسة المستخدم لمدة 7 أيام.
- مسار المعالجة:** `Frontend (POST /api/login) → backend/api/login.js` → قراءة المستخدم بـ `email` → مطابقة كلمة المرور بـ `bcrypt.compare()` → التحقق من `email_verified == true` → توليد `JWT` → استجابة `200` مع الرمز وكائن المستخدم.
- القواعد البرمجية والأمان:** - رسالة خطأ موحدة عند خطأ البريد أو كلمة المرور (401) لمنع تخمين الحسابات (Account Enumeration).
- منع دخول الحساب غير المفعل بإرجاع كود `403 Forbidden`.

المشكلة المرصودة: يرفض طلبات `OPTIONS` في بيئة Vercel Serverless، ويفتقر لحماية الـ `Rate Limiting` ضد هجمات القوة الغاشمة (Brute Force).

PARTIALLY WORKING ⚠️

Feature 3: Current User Profile (جلب بيانات الحساب الحالي)

1. **الغرض:** تمكين الواجهة الأمامية من قراءة وتأكيد بيانات الجلسة الحالية للمستخدم المسجل باستخدام الترويسة `<Authorization: Bearer <token>`.

2. **الملفات المسؤولة:** `backend/api/me.js` و دالة `verifySession` في `backend/api/_lib.js`.

3. **قاعدة البيانات:** استعلام `SELECT id, full_name, email, email_verified, created_at FROM public.users WHERE id = session.sub`

المشكلة المرصودة: لا يحيط استعلام قاعدة البيانات بـ `try/catch` داخل `me.js` مما يؤدي إلى `Unhandled Rejection` في حال انقطاع Supabase.

WORKING ✅

Feature 4: Email Verification (تأكيد البريد الإلكتروني بالرمز)

1. **الغرض:** تفعيل حساب المستخدم عند الضغط على الرابط المرسل لبريده، وإبطال الرمز لمنع إعادة استخدامه، وإصدار جلسة دخول فورية.

2. **مسار المعالجة:** `GET /api/verify-email?token=...` → حساب تجزئة SHA-256 للرمز → مطابقة السجل في جدول `users` → التحقق من عدم انتهاء الصلاحية (24 ساعة) → تحديث `email_verified=true` ومسح الرمز → استجابة 200 مع JWT جديد.

3. **التوافق الأمني:** - الرمز غير مخزن كنص صريح في قاعدة البيانات (SHA-256 Hashed).
- حماية تامة ضد هجمات `Replay Attacks`.
- استخدام كود `410 Gone` بدقة عند انتهاء صلاحية الرمز.

PARTIALLY WORKING ⚠️

Feature 5 & 6 & 7: استعادة الحساب وكلمة المرور (Recovery & Reset)

1. **إعادة إرسال رسالة التفعيل** (`POST /api/resent-verification`): يجدد الرمز ويمدد صلاحيته 24 ساعة ويرسل رسالة جديدة بحساب حيادي لا يكشف وجود المستخدم من عدمه.

2. **طلب استعادة كلمة المرور** (`POST /api/forgot-password`): يولد رمزاً عشوائياً بصلاحية 60 دقيقة فقط، ويحفظ تجزئته ويرسل رابط الاستعادة بالبريد.

3. **تأكيد كلمة المرور الجديدة** (`POST /api/reset-password`): يتأكد من مطابقة تجزئة الرمز وعدم انتهاء الوقت، ويشفر كلمة المرور الجديدة بـ `Bcrypt` ويمسح الرمز القديم.

الملاحظات: تتطلب وجود خادم SMTP مضبوط بمتغير `SMTP_PASS` لإرسال البريد الفعلي، بالإضافة إلى غياب `Rate Limiting` الذي يعرض السيرفر للسبام.

1. الغرض: نقطة نهاية داخلية تشخيصية آمنة (GET /api/health) تفحص الاتصال بقاعدة البيانات، والوصول لجدول المستخدمين، ومصادقة الـ SMTP، واكتمال 9 متغيرات بيئة إجبارية.

2. النتيجة الحالية في السيرفر الحي: الاتصال بـ Supabase سليم 100%، والجدول جاهز. يظهر فقط نقص متغيري SMTP_PASS و APP_URL في استضافة Vercel.

4. التدقيق الأمني (Security Audit)

الثغرات والتحسينات المطلوبة (Vulnerabilities):

- غياب Rate Limiting ضد هجمات القوة الغاشمة على Login و Forgot Password.
- غياب Regex Validation للتحقق من سلامة بنية البريد الإلكتروني.
- عدم وضع سقف لطول المدخلات (Max-length) لتفادي هجمات DoS على Bcrypt.

نقاط القوة الأمنية (Strengths):

- تشفير كلمات المرور بخوارزمية Bcrypt القوية (12 جولة).
- عدم تخزين رموز التحقق كنصوص صريحة بل كتجزئة SHA-256.
- عزل مفاتيح الخدمة Service Role و JWT Secret بالكامل عن الفرونت إند.
- حماية بيانات الحسابات من التخمين بردود موحدة.

5. التقرير الختامي وتوصيات الإصلاح (Final Report & Action Plan)

إجمالي الميزات المنفذة: 8 ميزات حقيقية متصلة بمنظومة المصادقة وصحة السيرفر.
الميزات السليمة منطقياً: كافة الميزات مكتوبة بخوارزميات برمجية سليمة وتعمل بنجاح محلياً.
سبب المشاكل الحالية على السيرفر الحي (Vercel):

1. عدم إضافة ملف `vercel.json` يحتوي على ترويسات CORS لمسارات `/api/` (* .) وعدم الرد على طلبات OPTIONS السابقة لـ `POST`.

2. نقص متغيري `SMTP_PASS` (كلمة مرور التطبيق لحساب Gmail) و `APP_URL` (رابط موقع الفرونت إند).

الترتيب الموصى به للإصلاح (Recommended Priority Order):

الأولوية	الإجراء المطلوب	السبب والأثر التقني
1 (درجة)	ضبط ترويسات CORS ومعالجة طلبات OPTIONS في الباك إند	السماح للفرونت إند بالتواصل مع الباك إند دون حجب من المتصفح في الإنتاج.
2 (درجة)	إضافة <code>SMTP_PASS</code> و <code>APP_URL</code> في إعدادات Vercel Backend	تمكين إرسال رسائل تفعيل البريد وروابط استعادة كلمة المرور للمستخدمين.
3 (متوسطة)	إضافة مكتبة أو منطق لتحديد معدل الطلبات (Rate Limiting)	حماية مسارات الدخول واستعادة الحساب من هجمات التخمين والإغراق بالبريد.
4 (تحسين)	إحاطة <code>api/me.js</code> بـ <code>try/catch</code> وإضافة التحقق من صيغة البريد بالـ <code>Regex</code>	تحسين مرونة النظام ومنع تسجيل بيانات غير صالحة.

تم إنشاء هذا التقرير الفني آلياً بناءً على التدقيق الشامل للشفرة المصدرية لـ Backend وقاعدة البيانات.